

KISA 기준 103 개 항목의 점검 · 조치를 자동화한 SSAP

서버마다 손으로 하던 보안 점검을 , Ansible 오케스트레이션과 웹 대시보드로 옮겼습니다 .

- 문제

서버마다 접속해 반복 점검 , 점검자마다 다른 판단
- 해결

KISA 기준을 스크립트로 만들어 여러 서버를 병렬 점검
- 문제

취약점 조치가 서비스 장애로 이어질 위험
- 해결

위험도로 자동 / 승인 조치를 나누고 , 조치 후 재점검
- 문제

결과 수집 · 보고서 · 이력 관리가 수작업
- 해결

표준 JSON → DB 적재 , 증적과 보고서 자동 생성

103 개 항목

UNIX 67 · WEB 26 · DBMS 10

170 개 일괄 점검

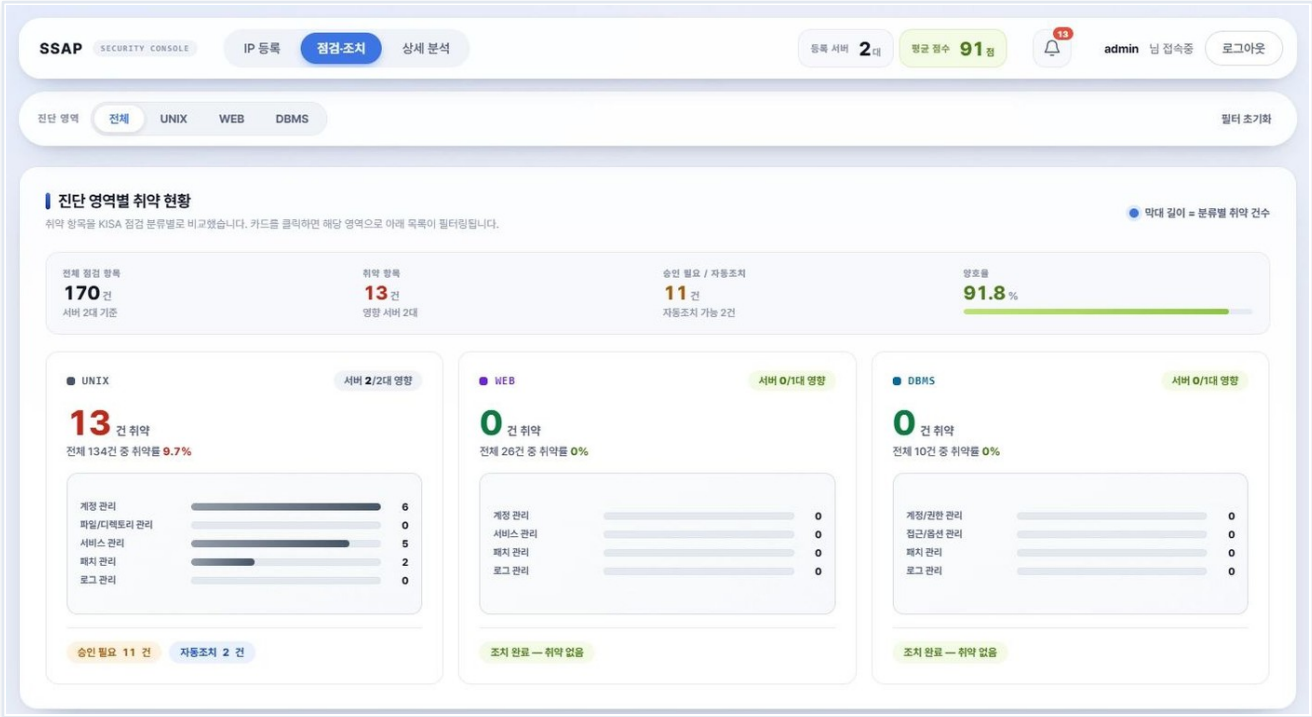
서버 2 대를 한 번에

41 건 탐지

취약 설정을 심은 회사

20/20 건 검증

작업 증적 SHA-256 무결성

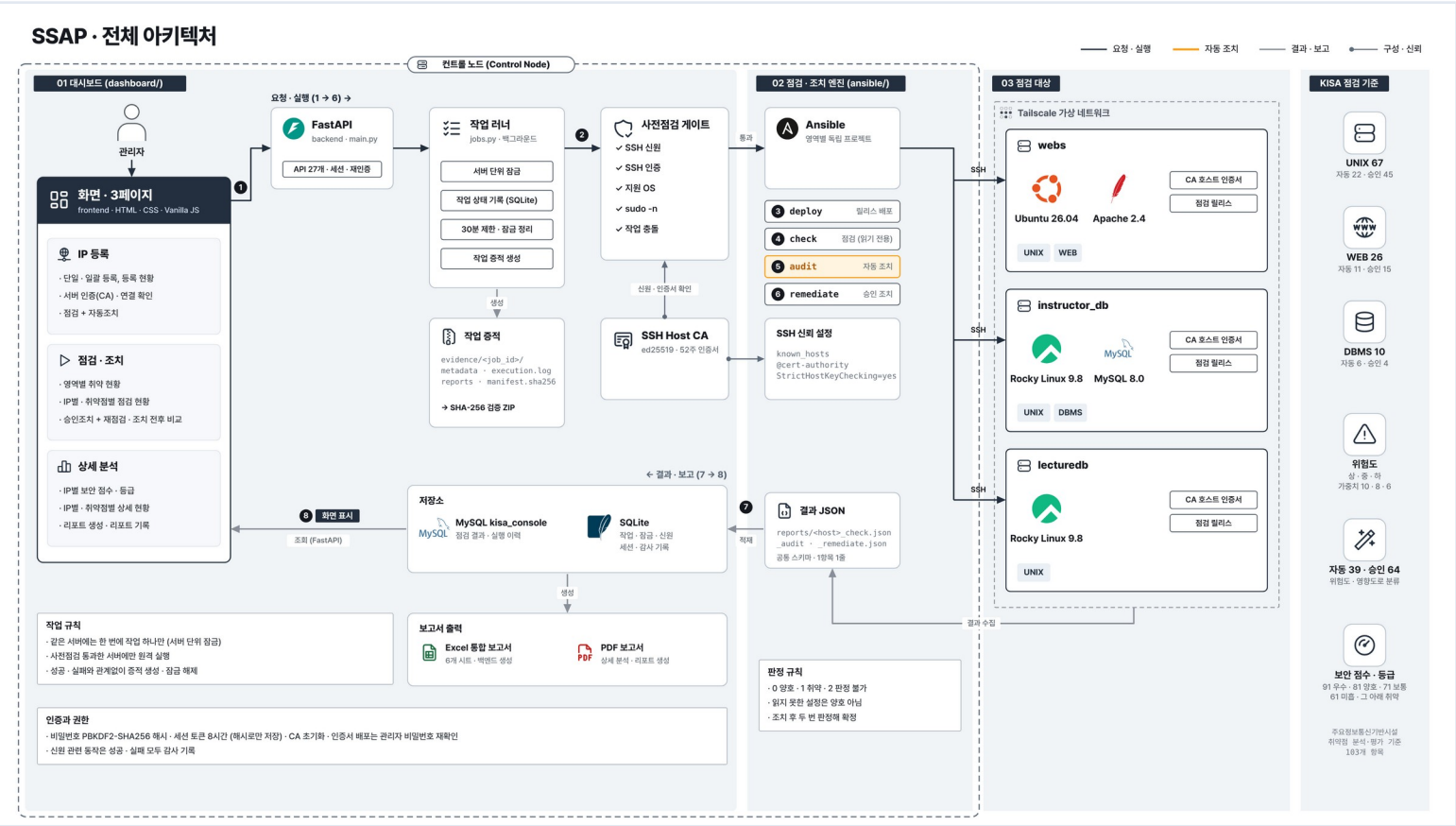


점검 · 조치 화면 — 진단 영역별 취약 현황과 승인 / 자동조치 분류

 **핵심**

KISA 기준을 코드로 · 위험도별 자동 / 승인 조치 + 재점검 · SSH Host CA · 사전점검으로 검증된 실행 · 작업마다 SHA-256 증적

세 영역 구조 : 검증을 통과한 서버에만 점검 · 조치를 실행



- 1 세 영역
컨트롤 노드에 01 대시보드 · 02 점검 · 조치 엔진, 그 바깥에 03 점검 대상 서버
- 2 요청 · 실행 ①→⑥
작업 러너가 서버 잠금 · 사전점검 후 Ansible 실행. 조치는 위험도로 자동 (39) · 승인 (64) 분리
- 3 결과 · 보고 ⑦→⑧
세 영역 공통 JSON → MySQL 적재 → 화면 3 페이지 · Excel · PDF 보고서, 작업마다 SHA-256 증명

내 역할

SSH Host CA 설계 · 구현 · 대시보드 개발 (FastAPI 백엔드 · 웹 프론트엔드) · 점검 스크립트 검증 (팀 공동)

SSH Host CA: 여러 서버로 늘어날 SSH 연결을 CA 하나로 검증

서버마다 호스트 키를 등록하는 대신, 컨트롤 노드는 CA 공개키 한 줄만 신뢰합니다.

100.122.19.67 · SSH Host CA 인증 상세

- Host CA 준비**
관리자가 상단에서 ed25519 SSH Host CA 키쌍을 1회 생성(ssh-keygen -t ed25519)해 모든 서버가 공유하는 신뢰 루트를 마련했습니다.
- 기존 지문 방식 승인**
콘솔에서 직접 확인한 SSH 호스트 키 지문을 네트워크 조회 결과와 대사해 2026.08.30 18:12에 최초 승인했습니다.
- CA 서명 인증서 발급·배포**
승인된 호스트 키에 ssh-keygen -s로 CA 서명을 붙이고(-h -n hostname,ip 로 principal 고정, 유효기간 1년), 관리자 재인증 후 SSH로 원격 sshd에 설치했습니다.

- sshd 설정 반영 검증**
원격에서 sshd_config를 백업한 뒤 sshd -t 문법 검사와 서비스 reload가 모두 성공한 경우에만 적용을 확정하고, 실패 시 자동으로 백업본으로 되돌립니다.
- 네트워크 재검증**
배포 후 ssh-keyscan으로 다시 조회해 CA 서명 인증서를 확인하고 2026.08.30 18:12에 'CA 인증' 상태로 전환했습니다.

인증서 지문 SHA256:IoT252t2wyevwJjomAx+gkTpo1FoTX3pQwkcs/gL0L0

감사 이력

2026.08.30 16:53 · cert_deploy → certificate_approved (admin)

2026.08.30 16:53 · bootstrap → auto_trusted_lab (admin)

실제 화면 — webs SSH Host CA 인증 상세 (2026.08.30)

등록된 IP 현황 (총 2건) 2건 선택됨

전체 서버 인증

전체 연결 확인

검정 + 자동조치

IP	호스트명	호스트명	HOST CA	접속 상태	등록일시	
☒ 100.122.19.67	webs	UNIX WEB	CA 인증	준비 완료	2026.08.30 17:56	삭제
☒ 100.120.178.40	instructor_db	UNIX DBMS	CA 인증	준비 완료	2026.08.30 16:21	삭제

도입 이유

지향점은 여러 대 서버의 점검 자동화 — 모든 작업이 SSH로 이뤄짐
서버마다 키 등록은 대수만큼 복잡 → CA 공개키 한 줄로 모든 서버 검증
운영 수준은 못 만들어도 3대 규모에서 구조부터 확인

부분적으로 성공

된 것: 지문 대조 승인 (불일치 거부), 인증서 배포 · 재조회 검증, 실패시 원복, StrictHostKeyChecking 강제, 재인증 · 감사 기록
부분: 실습용 bootstrap(처음 본 키 신뢰)도 열려 있음 · 검증 강제는 대시보드 경로만

실습 제한으로 못 한 것

CA 키 암호화 · HSM/Vault 분리 · CA 교체 (rotation)
인증서 폐기 목록 (KRL) · 자동 갱신 · 다수 서버 검증



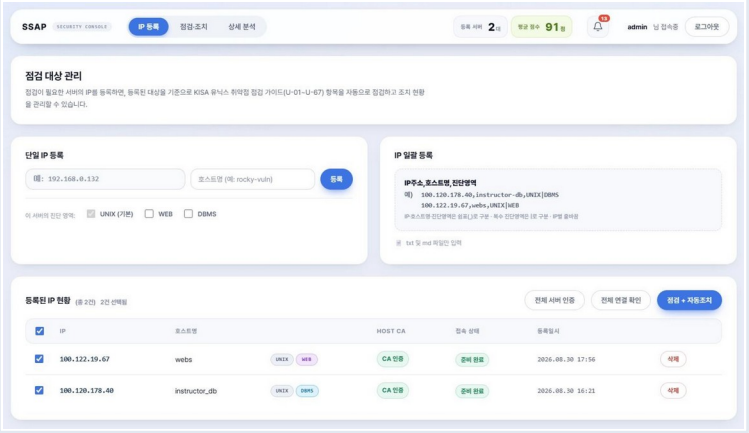
성과

서버 3대 CA 인증 · 대시보드 작업은 미서명 · 만료 · 이름 불일치 서버 접속 차단 · 신원 작업 성공 · 실패 모두 감사 기록

대시보드 : 등록부터 점검 · 조치 , 분석 · 보고서까지 화면 3 페이지로

FastAPI REST API 27 개 · 작업 러너 (서버 잠금 · 사전점검 · 증적) · HTML / CSS / Vanilla JS

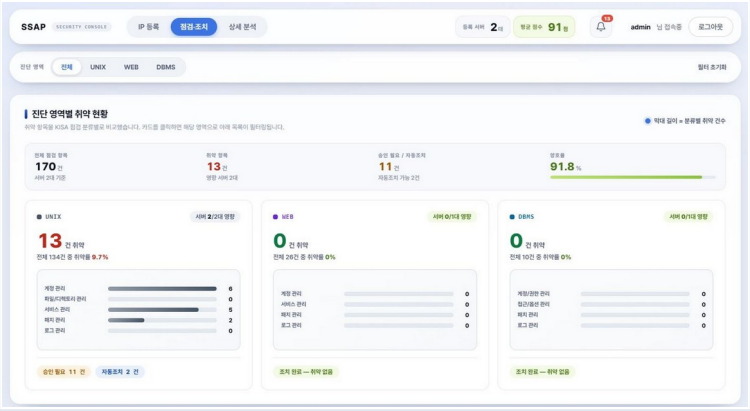
IP 등록 등록 · 서버 인증 (CA) · 연결 확인 · 점검 실행



조치 전후 비교 자동조치 후에도 미해결 2 건을 그대로 표시



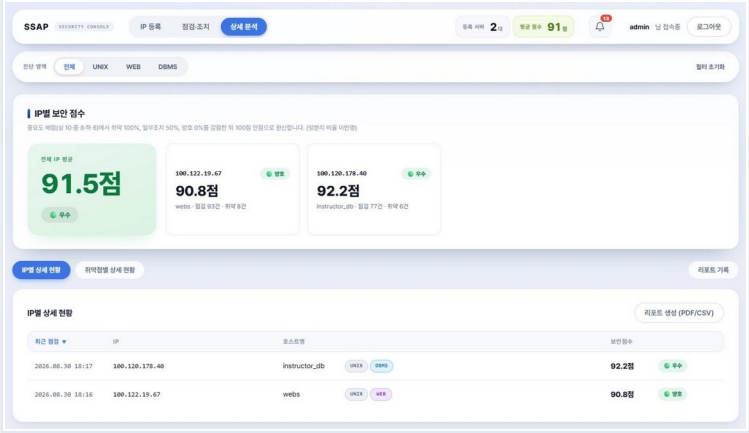
점검 · 조치 영역별 취약 현황 , 자동 / 승인 조치 분류



보고서 항목마다 진단 근거가 담긴 PDF · 통합 Excel



상세 분석 IP 별 보안 점수 · 등급 , 항목별 상세



작업 증적 작업마다 파일별 SHA-256 · 사전점검 10/10



 **성과**

사전점검 10/10 통과 후 실행 · 작업 증적 20/20 SHA-256 검증 · 조치 전후 비교로 미해결 2 건 확인